BÁO CÁO KIỂM THỬ

Tính năng sửa điểm — miniLMS

Áp dụng defensive pattern #3: Optimistic Locking

Mục	Nội dung
Hệ thống	miniLMS — Hệ thống quản lý học tập
Nhóm	Nhóm 02
Thành viên	Sinh viên A (MSSV) — phụ trách sửa điểm Sinh viên B (MSSV) — phụ trách nộp bài
Phiên bản	v1.0 — nhánh optimistic-locking
Môi trường	http://127.0.0.1:8888
Công nghệ	Python 3.12, Flask, SQLAlchemy, PostgreSQL 18
Thời gian	05/11/2026 – 06/11/2026
Phạm vi	Chức năng sửa điểm bài nộp và điểm bài kiểm tra; phân quyền liên quan
Ngoài phạm vi	Đồng bộ nhiều máy chủ, dịch vụ email, thanh toán, tấn công từ chối dịch vụ
Công cụ	pytest (133 test); script tools/pattern_evidence.py; Flask test client mô phỏng HTTP; PostgreSQL psql

1. Thông tin chung

Báo cáo kiểm thử chức năng sửa điểm của miniLMS sau khi áp dụng Optimistic Locking. Mục tiêu: xác nhận các lỗi nhân tạo đã được tái hiện ở bản trước khi sửa, được khắc phục ở bản sau khi sửa và không còn tái diễn.

2. Tóm tắt kết quả

Kiểm thử được thực hiện trong hai ngày trên môi trường dev với PostgreSQL. Ba lỗi được phát hiện và đã khắc phục: một lỗi mất cập nhật khi hai người sửa cùng lúc (mức CAO), một lỗi máy chủ trả 500 khi chỉnh điểm quiz và một lỗi thiếu kiểm tra dữ liệu khiến điểm ngoài miền được chấp nhận và nhận xét bị xoá (mức TRUNG BÌNH). Toàn bộ 133 test đều đạt, trong đó 7 test mới bao phủ trực tiếp nghiệp vụ sửa điểm.

Mức độ	Số lượng
CAO	1
TRUNG BÌNH	2
THẤP	0
THÔNG TIN	0
Tổng	3

Tiêu chí phân loại mức độ

- CAO: làm sai dữ liệu học vụ hoặc cho phép thay đổi điểm của người khác mà không bị phát hiện.
- TRUNG BÌNH: chức năng lỗi/không dùng được hoặc làm mất dữ liệu phụ, cần quyền hợp lệ để khai thác.

- THẤP: ảnh hưởng giao diện, khó khai thác hoặc tác động không đáng kể.
- THÔNG TIN: không phải lỗ hổng trực tiếp, là điểm cần cải thiện.

3. Tổng hợp lỗi

Mã	Tên lỗi	Mức độ	Vị trí	Đã sửa	Kiểm tra lại
V01	Mất cập nhật khi hai người sửa điểm cùng lúc (lost update)	CAO	POST /assignments/{id}/submissions/{sid}/grade POST /admin/grades/assignment/{sid}/adjust POST /admin/grades/quiz/{aid}/adjust	☒	☒
V02	Máy chủ trả 500 khi chỉnh điểm quiz	TRUNG BÌNH	POST /admin/grades/quiz/{aid}/adjust	☒	☒
V03	Thiếu kiểm tra dữ liệu: nhận điểm ngoài miền, xoá nhận xét	TRUNG BÌNH	POST /admin/grades/assignment/{sid}/adjust	☒	☒

4. Chi tiết lỗi

Mỗi lỗi trình bày theo cấu trúc: vị trí, mô tả, bước tái hiện, bằng chứng, tác động, nguyên nhân trong mã nguồn, biện pháp khắc phục và kết quả kiểm tra lại.

V01 — Mất cập nhật khi hai người sửa điểm cùng lúc (lost update)

V01 · Mức độ: CAO

Vị trí

POST /assignments/{id}/submissions/{sid}/grade; POST /admin/grades/assignment/{sid}/adjust; POST /admin/grades/quiz/{aid}/adjust.

Mô tả

Máy chủ đọc bản ghi điểm rồi ghi đè mà không kiểm tra bản ghi đã bị người khác sửa kể từ lúc biểu mẫu được tải hay chưa. Hai giảng viên/quản trị mở cùng một bản ghi, người lưu sau ghi đè thay đổi của người trước; hệ thống không báo xung đột.

Các bước tái hiện

1. Đăng nhập giảng viên A, mở bài nộp có điểm 5 và nhận xét “Tốt”.
2. Đăng nhập giảng viên B trên trình duyệt khác, mở cùng bài nộp.
3. A nhập 9 và lưu. Cơ sở dữ liệu ghi score = 9.
4. B (vẫn đang thấy điểm 5) nhập 2 và lưu. Cơ sở dữ liệu ghi score = 2.
5. A tải lại trang: điểm 9 đã biến mất, không có thông báo nào.

Bằng chứng

```
POST /admin/grades/assignment/1/adjust
score=2&version=1

TRƯỚC KHI SỬA
  HTTP/1.1 302 Found
  DB: score=2.0, version=1   <- thay đổi 9 của A bị ghi đè

SAU KHI SỬA
  HTTP/1.1 409 Conflict
  {"conflict": "Điểm đã được người khác cập nhật. Vui lòng tải lại trang."}
  DB: score=9.0, version=2   <- giữ nguyên thay đổi của A
```

Tác động

Điểm học vụ có thể sai mà không ai biết; mất nhận xét; ảnh hưởng xếp loại, chứng chỉ và gây khiếu nại. Mức CAO vì thay đổi dữ liệu học tập của người khác một cách âm thầm.

Nguyên nhân trong mã nguồn (bản trước khi sửa)

```
submission = sess.get(Submission, submission_id)
old_score = submission.score
submission.score = float(new_score)      # không kiểm tra version
submission.feedback = feedback
sess.flush()                              # last-write-wins
```

Biện pháp khắc phục (bản sau khi sửa)

Bổ sung cột version cho submissions và quiz_attempts; biểu mẫu gửi kèm version đã đọc. Service thực hiện UPDATE có điều kiện version (compare-and-set nguyên tử), kiểm tra số dòng bị tác động; lệch version trả 409 và ghi nhật ký GRADE_CONFLICT.

```
expected = parse_version(expected_version_raw)
...
result = sess.execute(
    update(Submission)
    .where(Submission.id == submission_id,
           Submission.version == expected)
    .values(score=new_score, version=expected + 1, ...)
)
if result.rowcount == 0:
    audit_record("GRADE_CONFLICT", ...)
    raise GradeConflict(current.score, current.version)
```

Kiểm tra lại

Lặp lại bước 3–4: A lưu 9 thành công (version 2); B gửi version 1 nhận 409, cơ sở dữ liệu vẫn là 9. Test tự động test_sua_diem_version_cu_tra_409_va_khong_ghi_de đạt. Đã khắc phục.

V02 — Máy chủ trả 500 khi chỉnh điểm quiz

V02 · Mức độ: TRUNG BÌNH

Vị trí

POST /admin/grades/quiz/{attempt_id}/adjust — trang /admin/grades.

Mô tả

Mã cũ truy cập attempt.quiz.pass_score, nhưng QuizAttempt không khai báo quan hệ quiz. Mọi lần chỉnh điểm quiz đều ném AttributeError và trả HTTP 500, chức năng không dùng được.

Các bước tái hiện

1. Đăng nhập quản trị, mở /admin/grades.
2. Ở bảng Quiz Attempts, nhập điểm mới 8 và bấm Lưu.
3. Máy chủ trả 500 kèm traceback AttributeError.

Bằng chứng

```
POST /admin/grades/quiz/4/adjust  score=8

TRƯỚC: HTTP/1.1 500 Internal Server Error
  AttributeError: 'QuizAttempt' object has no attribute 'quiz'
  File web/blueprints/admin.py, line 671

SAU:   HTTP/1.1 302 Found -> /admin/grades
  DB: score=8.0, version=2, passed=True
```

Tác động

Quản trị viên không thể sửa điểm quiz; trang lộ stack trace khi bật debug, gây rò rỉ thông tin nội bộ.

Nguyên nhân trong mã nguồn (bản trước khi sửa)

```
attempt.score = float(new_score)
attempt.passed = attempt.score >= attempt.quiz.pass_score
#                            ^^^^^^^^^^^^ không tồn tại
```

Biện pháp khắc phục (bản sau khi sửa)

Lấy Quiz theo khoá ngoại quiz_id, kiểm tra tồn tại, rồi tính passed theo pass_score; đưa toàn bộ logic vào grade_service.update_quiz_grade kèm kiểm tra version và miền điểm.

```
quiz = sess.get(Quiz, attempt.quiz_id)
if quiz is None:
    raise GradeNotFound("Không tìm thấy bài kiểm tra.")
...
attempt.passed = new_score >= float(quiz.pass_score)
```

Kiểm tra lại

Lưu điểm 8 trả 302; cơ sở dữ liệu score=8, passed=True (pass_score=5), version=2. Test test_admin_sua_diem_quiz_khong_con_500 đạt. Đã khắc phục.

V03 — Thiếu kiểm tra dữ liệu: điểm ngoài miền và xoá nhận xét

V03 · Mức độ: TRUNG BÌNH

Vị trí

POST /admin/grades/assignment/{submission_id}/adjust (và các endpoint chấm điểm bài nộp).

Mô tả

Điểm được ép kiểu float trực tiếp, không kiểm tra miền [0, max_score] nên chấp nhận 99, -1, NaN. Đồng thời feedback lấy mặc định chuỗi rỗng và luôn gán, nên yêu cầu không gửi trường feedback sẽ xoá nhận xét đã có.

Các bước tái hiện

1. Bài nộp có score=8.5, feedback="Tốt", mở /admin/grades.
2. Gửi yêu cầu chỉnh điểm score=99 (không kèm feedback).
3. Hệ thống lưu score=99 và feedback rỗng; không có lỗi.

Bằng chứng

```
POST /admin/grades/assignment/1/adjust
score=99

TRƯỚC: HTTP/1.1 302
  DB: score=99.0, feedback=''      <- sai miền, mất nhận xét

SAU:   HTTP/1.1 302 (flash lỗi), DB không đổi
  "Điểm phải nằm trong khoảng 0–10.0."

Với score=7 (không gửi feedback):
  TRƯỚC: feedback=''
  SAU:   feedback='Tốt'  <- giữ nguyên nhận xét
```

Tác động

Điểm vượt thang 10 hoặc âm làm sai bảng điểm, xếp hạng, điều kiện cấp chứng chỉ; mất nhận xét của giảng viên.

Nguyên nhân trong mã nguồn (bản trước khi sửa)

```
new_score = request.form.get("score")
feedback = request.form.get("feedback", "")    # thiếu -> ""
...
submission.score = float(new_score)               # không kiểm tra miền
submission.feedback = feedback                    # luôn ghi đè
```

Biện pháp khắc phục (bản sau khi sửa)

parse_score chuẩn hoá dấu phẩy thập phân, từ chối NaN/Infinity và giá trị ngoài [0, max_score]. Chỉ cập nhật feedback khi client thực sự gửi trường này (khác None).

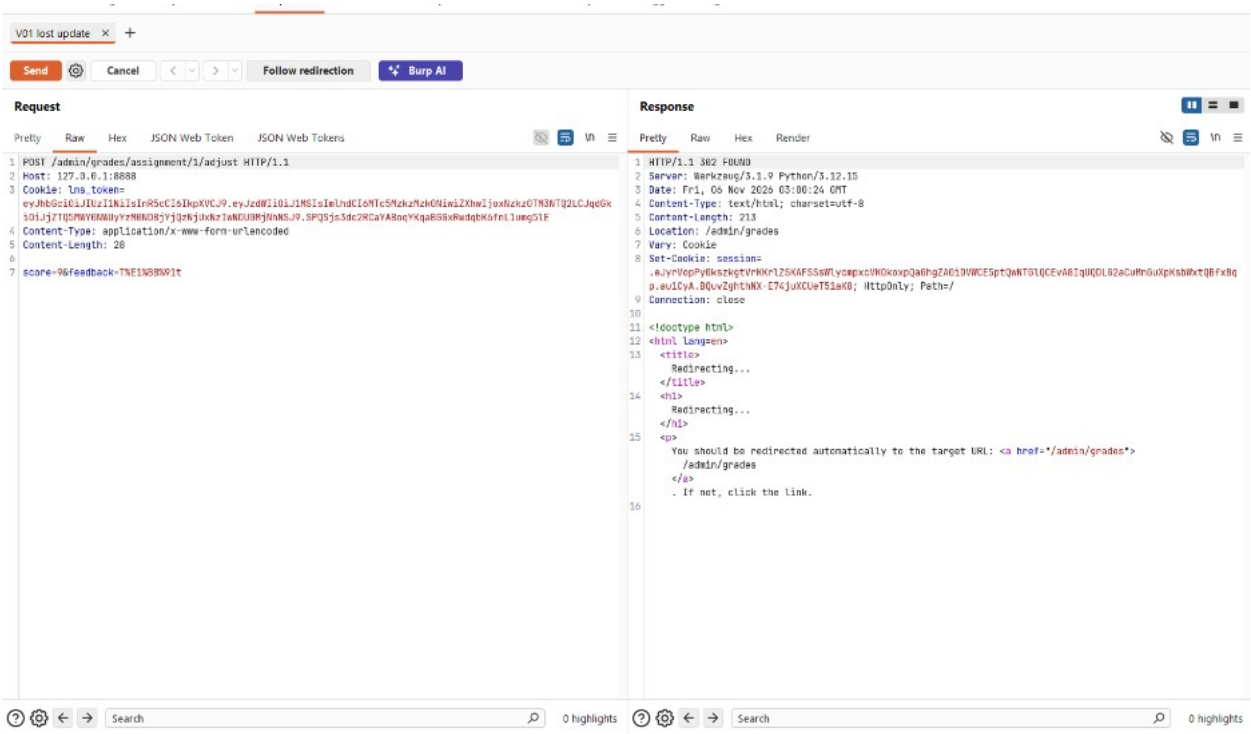
```
value = float(str(raw).strip().replace(",", "."))
if not math.isfinite(value):
    raise GradeValidationError("Điểm phải là số hữu hạn.")
if value < 0 or value > float(max_score):
    raise GradeValidationError(f"Điểm phải nằm trong khoảng 0–{max_score}.")
...
if feedback_raw is not None:          # không gửi thì giữ nguyên
    submission.feedback = str(feedback_raw).strip() or None
```

Kiểm tra lại

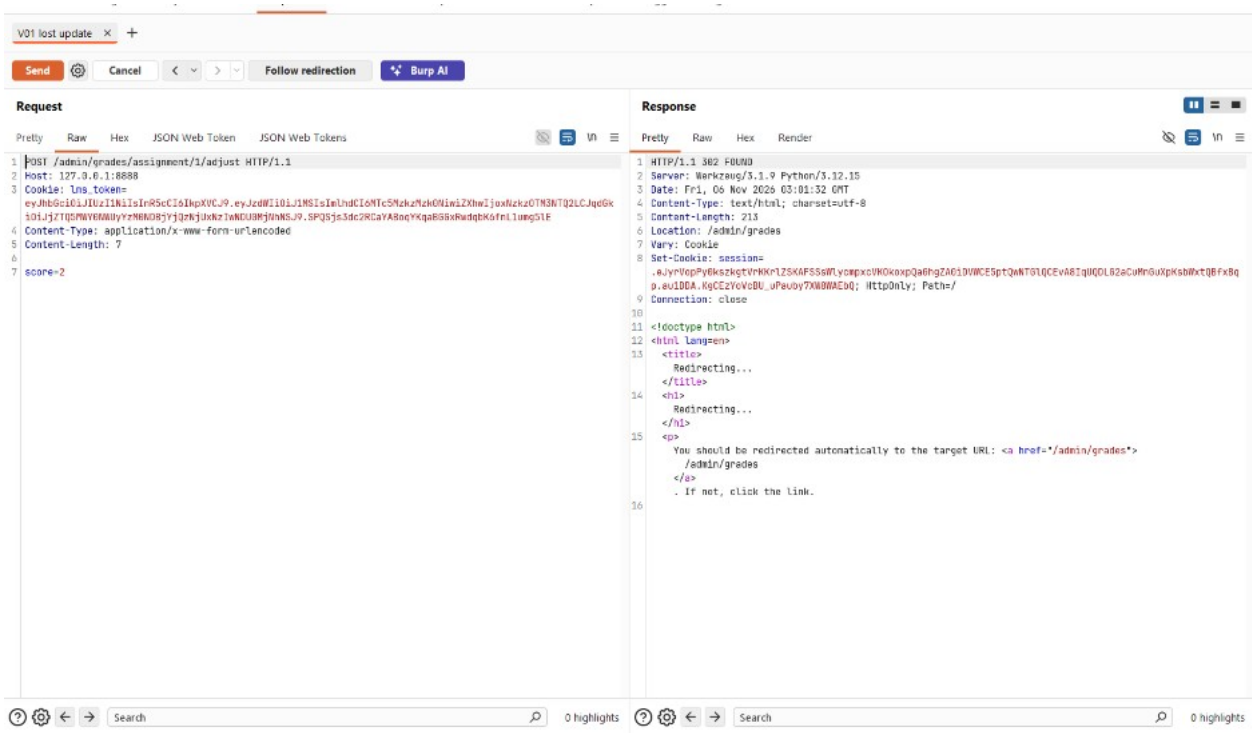
Bốn giá trị 99, -1, abc, nan đều bị từ chối, cơ sở dữ liệu không đổi; chỉnh điểm không kèm feedback giữ nguyên "Tốt". Test test_diem_ngoai_mien_bi_tu_choi và test_sua_diem_dung_version_va_giu_nhan_xet đạt. Đã khắc phục.

5. Ảnh PoC thực hiện bằng Burp Suite

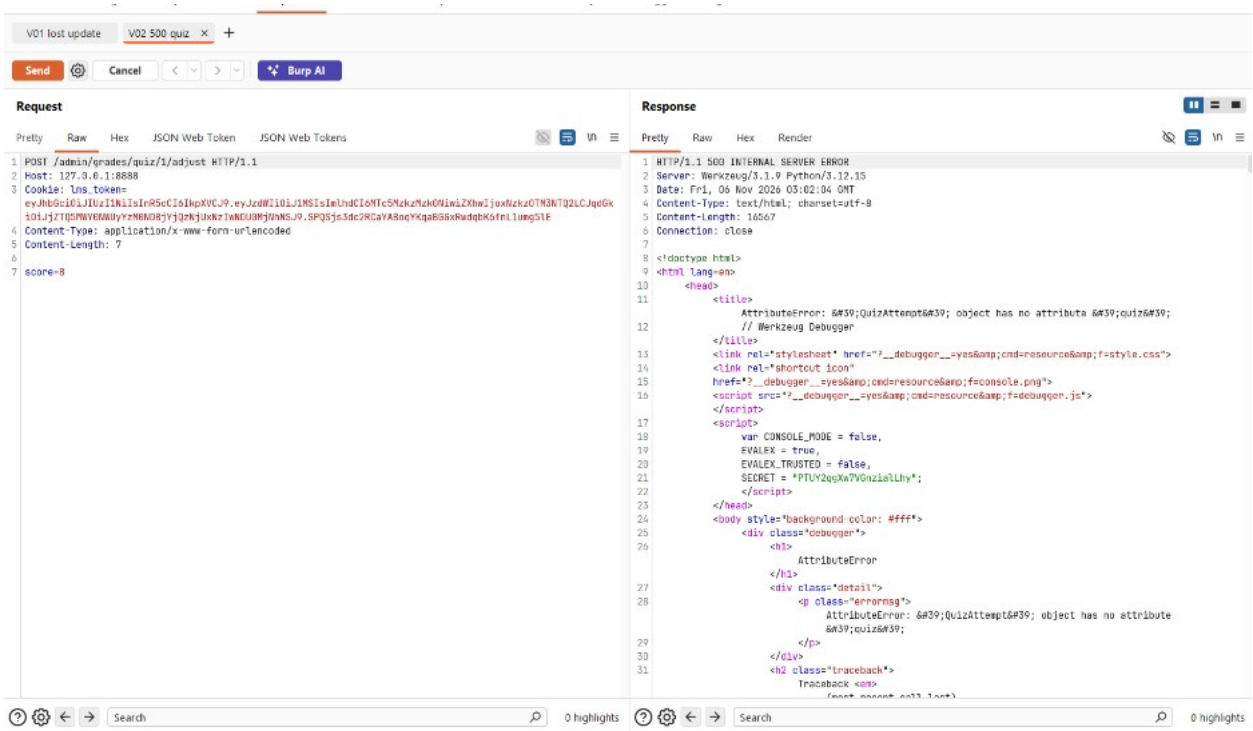
Các ảnh dưới đây được chụp trực tiếp từ Burp Suite (tab Repeater) khi tái hiện trên nhánh sua-diem-vuln, gửi tới http://127.0.0.1:8888. Ảnh giữ nguyên thanh công cụ, request bên trái và response bên phải để đối chiếu.



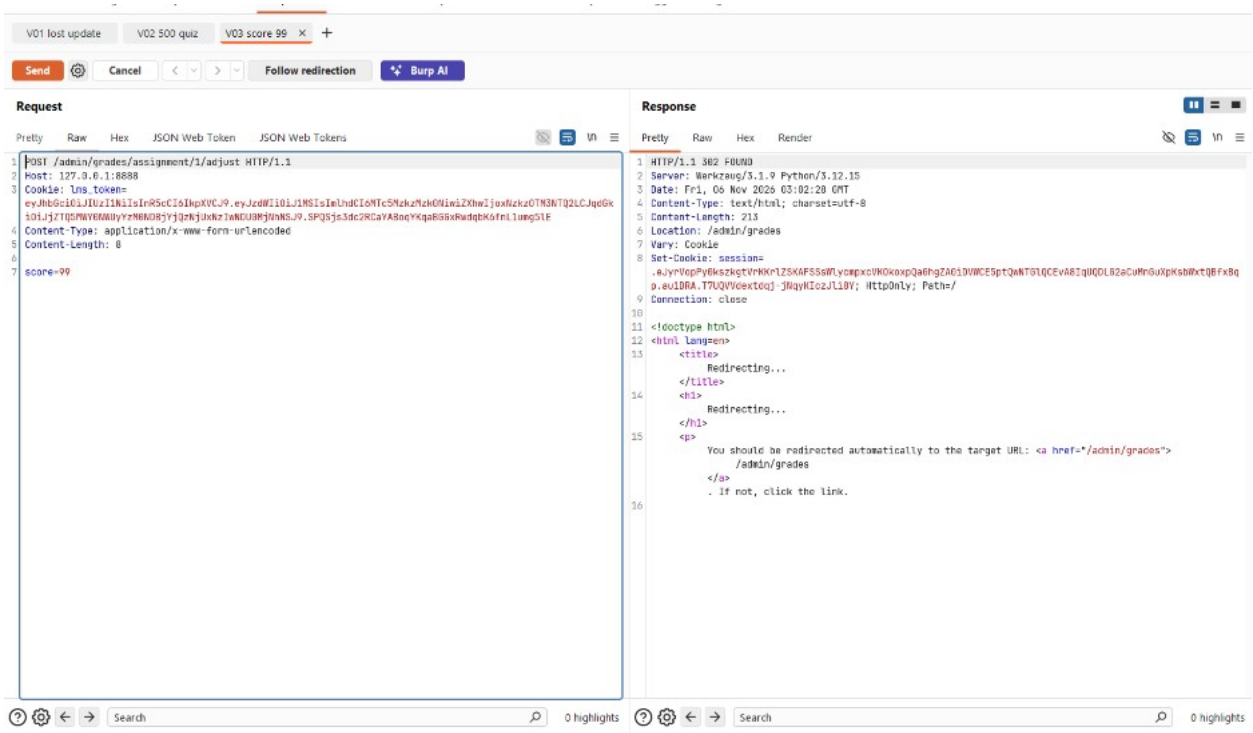
Ảnh 1 — V01 lần 1: score=9, server trả 302 (lưu thành công).



Ảnh 2 — V01 lần 2: score=2, vẫn 302; điểm 9 của lần trước bị ghi đè.



Ảnh 3 — V02: chỉnh điểm quiz trả 500, AttributeError: 'QuizAttempt' object has no attribute 'quiz'.



Ảnh 4 — V03: score=99 không kèm feedback, server vẫn trả 302 và ghi vào DB.

Đối chiếu dữ liệu sau mỗi PoC

```
-- Sau V01 lần 2 (score=2):
select id, score, feedback from submissions where id=1;
  id | score | feedback
 ----+-------+----------
   1 |     2 | Tốt

-- Sau V03 (score=99, không gửi feedback):
select id, score, feedback, length(feedback) from submissions where id=1;
  id | score | feedback | length
 ----+-------+----------+--------
   1 |    99 |          |      0
```

6. Danh mục kiểm thử

Ký hiệu: ☒ đã kiểm thử, không phát hiện lỗi; LỖI phát hiện lỗi (kèm mã); N/A không áp dụng.

Mã	Nội dung kiểm thử	Công cụ	Kết quả
G01	Sửa điểm với version hiện tại thành công, version tăng 1	pytest	☒
G02	Sửa điểm với version cũ trả 409, dữ liệu không đổi	pytest	LỖI (V01) → ☒
G03	Yêu cầu thiếu version bị từ chối	pytest	☒
G04	Chỉnh điểm quiz không còn 500, passed tính đúng	pytest	LỖI (V02) → ☒
G05	Chỉnh điểm quiz với version cũ trả 409	pytest	LỖI (V01) → ☒
G06	Điểm ngoài miền (99, -1) bị từ chối	pytest, script	LỖI (V03) → ☒
G07	Điểm không phải số hoặc NaN bị từ chối	pytest, script	LỖI (V03) → ☒
G08	Không gửi feedback thì nhận xét cũ được giữ	pytest, script	LỖI (V03) → ☒
G09	Bảng điểm admin hiển thị version trên từng biểu mẫu	pytest	☒
G10	Giảng viên không dạy khoá không chấm được điểm	pytest	☒
G11	Sinh viên gọi endpoint chấm/sửa điểm bị chặn 403	pytest	☒
G12	Hai người sửa đồng thời: chỉ một thay đổi được ghi	script evidence	LỖI (V01) → ☒

Tổng: 133 test đạt (126 test cũ + 7 test mới cho sửa điểm).

7. Đánh giá và bài học

Optimistic Locking xử lý đúng lớp lỗi mất cập nhật mà các bài kiểm thử tuần tự không phát hiện được; version phải đi kèm biểu mẫu và được kiểm tra ở tầng service, không chỉ ở giao diện. Việc tách grade_service giúp mọi entry point (giảng viên, quản trị, quiz, bài nộp) dùng chung một quy tắc kiểm tra và ghi nhật ký. Bài học: luôn kiểm tra dữ liệu ở server, không tin giá trị từ form; với dữ liệu có tranh chấp, cần thiết kế cơ chế phiên bản ngay từ đầu thay vì bổ sung sau.

Phụ lục A — Mã nguồn bản trước khi sửa

Tệp docs/patterns/sua_diem_truoc_khi_sua.py (trích nguyên trạng logic cũ, chỉ dùng để minh hoạ).

```
"""BẢN TRƯỚC KHI SỬA — trích nguyên trạng logic sửa điểm cũ.

Chỉ dùng cho mục đích minh hoạ/báo cáo, KHÔNG được import vào ứng dụng.
Tương ứng admin.py (grade_quiz_adjust, grade_assignment_adjust) trước pattern.
"""

from __future__ import annotations

from sqlalchemy.orm import Session

from web.models import QuizAttempt, Submission


def adjust_assignment_old(
    sess: Session, submission_id: int, score_raw: str, feedback_raw: str | None = None
) -> float:
    submission = sess.get(Submission, submission_id)
    if submission is None:
        raise LookupError("submission not found")
    old_score = submission.score
    submission.score = float(score_raw)          # V02: không kiểm tra miền/NaN
    submission.feedback = feedback_raw or ""     # V03: thiếu field -> xoá nhận xét
    sess.flush()
    return old_score


def adjust_quiz_old(sess: Session, attempt_id: int, score_raw: str) -> float:
    attempt = sess.get(QuizAttempt, attempt_id)
    if attempt is None:
        raise LookupError("attempt not found")
    old_score = attempt.score
    attempt.score = float(score_raw)
    attempt.passed = attempt.score >= attempt.quiz.pass_score  # V02: AttributeError
    sess.flush()
    return old_score
```

Phụ lục B — Bằng chứng before/after

Kết quả chạy tools/pattern_evidence.py trên cơ sở dữ liệu tạm (SQLite in-memory).

```
======================================================================
BẰNG CHỨNG BEFORE/AFTER — PATTERN #3 OPTIMISTIC LOCKING
Tính năng: sửa điểm bài nộp / điểm quiz
======================================================================

### V01 — Mất cập nhật khi hai người sửa cùng lúc (lost update)

[BEFORE] Trạng thái ban đầu: score=5, version=1
[BEFORE] Người A lưu 9 → người B lưu 2. Kết quả DB: score=2.0, version=1
[BEFORE] KẾT LUẬN: thay đổi 9 của A bị ghi đè âm thầm, không báo lỗi.

[AFTER] Reset: score=5, version=1
[AFTER] Người A lưu 9 (version=1) → DB: score=9.0, version=2
[AFTER] Người B lưu 2 (version=1) → bị chặn: Điểm đã được người khác cập nhật. Vui lòng tải lại trang.
[AFTER] KẾT QUẢ DB: score=9.0, version=2
[AFTER] KẾT LUẬN: không ghi đè; client nhận 409 và phải tải lại.

### V02 — 500 khi chỉnh điểm quiz (AttributeError attempt.quiz)

[BEFORE] Gọi adjust_quiz_old():
[BEFORE] AttributeError: 'QuizAttempt' object has no attribute 'quiz' → HTTP 500

[AFTER] update_quiz_grade() dùng Quiz lấy theo quiz_id:
[AFTER] score=8.0, version=2, passed=True (pass_score=5.0)
[AFTER] KẾT LUẬN: không còn 500; passed tính đúng theo pass_score.

### V03 — Nhận xét bị xoá khi yêu cầu không gửi trường feedback

[BEFORE] feedback='Tốt', gửi {score: 7} (không có feedback):
[BEFORE] DB sau đó: score=7.0, feedback='' → nhận xét bị xoá

[AFTER] feedback='Tốt', gửi {score: 7} (không có feedback):
[AFTER] DB sau đó: score=7.0, feedback='Tốt' → nhận xét được giữ

### Kiểm tra miền điểm (bổ sung trong bản AFTER)
  score='99': bị chặn — Điểm phải nằm trong khoảng 0–10.0.
  score='-1': bị chặn — Điểm phải nằm trong khoảng 0–10.0.
  score='abc': bị chặn — Điểm phải là một số.
  score='nan': bị chặn — Điểm phải là số hữu hạn.
  DB cuối: score=5.0, version=1 (không đổi)

======================================================================
KẾT LUẬN: cả 3 lỗi đã được xử lý; 2 lỗi cuối có test hồi quy riêng.
======================================================================
```

Phụ lục C — Danh sách kiểm thử tự động

Tệp tests/test_grade_optimistic.py gồm 7 test:

- test_sua_diem_dung_version_va_giu_nhan_xet
- test_sua_diem_version_cu_tra_409_va_khong_ghi_de
- test_thieu_version_bi_tu_choi
- test_diem_ngoai_mien_bi_tu_choi
- test_admin_sua_diem_quiz_khong_con_500
- test_admin_sua_diem_quiz_version_cu_tra_409
- test_bang_diem_hien_thi_version